EWB COURSES

AI-POWERED CYBERSECURITY

ASSESSMENT 01: SECURITY FOUNDATIONS

Name: Jambukeswari

Batch/Group: 1

Assessment type: Individual work (100 marks)

Issued: 18 October 2026

Contents: Task A (Secure a student account) | Task B (Analyse a suspicious message) | Task C (Triage a sign-in alert) | Task D (Review an AI security answer) | References and AI-use declaration

Task A: Secure a student account (25 marks)

A1 and A2. Risks, assets, CIA impact, controls and limitations

A risk is a possible way an asset could be harmed; it is not proof that an attack has happened. CIA means confidentiality (only the right people see data), integrity (data is not wrongly changed) and availability (data can be used when needed).

Risk	Asset	CIA impact	Control	Limitation
1. Same short password for email and learning portal	Email and portal accounts	Confidentiality: one guessed or leaked password opens both accounts. Integrity: an intruder could change data or reset other passwords.	Use a long, unique password for each account, stored in a password manager.	Still stealable by phishing or malware; the manager's master password must itself be strong.
2. Approves unexpected sign-in prompts	Accounts protected by MFA	Confidentiality and integrity: approving lets an unknown person in and act as Mira.	Deny any prompt she did not start, report repeated prompts to IT, then change the password.	Depends on Mira noticing every time; one mistaken approval can still give access.
3. Postpones device updates	Laptop and the data on it	Confidentiality, integrity and availability: known flaws can be used to read, change or lock files.	Turn on automatic security updates and restart when asked.	Fixes only known flaws; does not stop phishing or unknown flaws.
4. Only one copy of the project	Project files	Availability: theft, damage, failure or malware could make the work unavailable (integrity if files are corrupted).	Keep a second copy on cloud storage or an external drive and refresh it regularly.	A backup may be outdated, or also damaged if it syncs automatically with infected files.
5. Friend uses the laptop under Mira's signed-in account	Email, portal and assignments	Confidentiality and integrity: the friend can read private data or edit or send things as Mira.	Lock the screen, sign out before lending the laptop, and give the friend a separate guest account.	Works only if Mira follows it every time; a weak lock or shared password weakens it.

Top three priorities and why

1. **Fix passwords and prompts first.** If an account is already exposed, damage can spread to everything linked to it. This step is free, quick and removes the most serious risk.
2. **Stop shared signed-in use.** Another person has direct access right now, so signing out and using a guest account closes an open door immediately.
3. **Back up the project, then install updates.** These protect against loss and known flaws, but they reduce future harm rather than stopping an ongoing exposure, so they come after the first two.

A3. Authentication versus authorisation

Authentication proves who a user is. When Mira types her password and approves her own MFA prompt, the learning portal checks that she is really Mira. Authorisation decides what that proven user may do. Once signed in, Mira can view her own marks and download course material, but she cannot edit her marks or see other students' records. In short, authentication asks "Who are you?" and authorisation asks "What are you allowed to do?"

Task B: Analyse a suspicious message (25 marks)

B1. Warning signs in the message

Quoted phrase	Why it needs scrutiny
"FINAL WARNING" and "expires in 20 minutes"	Artificial urgency pushes the reader to act before checking.
awards@campus-awards.example	The college normally uses campus.example, so this different domain must be verified independently. It is a warning sign, not proof by itself.
Reply-To: help@personal-awards.example	Replies would go to a third domain that differs from the sender and from the college domain.
"enter your college password and OTP"	Legitimate offices do not ask for a password and one-time code through a message link. Together they give full account access.
"Do not contact the college office"	It tries to stop the reader from checking with the real source.
"Reply with a photo of your identity card"	It asks for sensitive identity data over an unsafe channel, risking identity misuse.

B2. Safe verification process

1. Do not click the link, reply, or send any password, OTP or ID photo.
2. Open the college's official portal from a saved bookmark or by typing the known address yourself.
3. Contact the college office using a phone number or email obtained from official college material, not from this message, and ask whether any scholarship notice exists.
4. Report the message to the official IT contact and then delete it only if IT says so.

A familiar display name can be copied by anyone, and HTTPS only encrypts the connection to a site; it does not prove that the site or sender is honest. Fraudulent sites can also use HTTPS.

B3. Response plan if a password and OTP were entered

1. **Contain:** From a trusted device, use the official site to change the password immediately, and change it on any other account where it was reused. Sign out unknown sessions and re-check MFA settings. If locked out, contact official IT support.
2. **Report:** Tell the college IT/security contact what was entered, when, and keep the message as evidence. Never send the password or OTP to anyone, including IT.
3. **Follow up:** Check recent sign-ins, recovery email and phone, forwarding rules and account changes. Watch the account for several days and follow IT's instructions.

B4. A fact the message cannot establish

The message alone cannot show who really sent it. Helpful extra evidence would be the full email headers (checked by authorised staff) and confirmation from the college that no such scholarship notice was issued.

Task C: Triage a sign-in alert (25 marks)

C1. Four-point timeline (IST, 18 October 2026)

Time	Observed (from logs or statement)	Interpretation (not proven)
09:00-09:01	student07 passed password and MFA from 192.0.2.10, the usual classroom IP.	Looks like a normal sign-in, though logs alone do not name the person.
10:14-10:16	From 198.51.100.23: two failed passwords, then a successful password.	Could be password guessing or someone who knew the password. A new IP alone does not prove an attacker.
10:17-10:18	MFA denied, then approved. Student says they approved a prompt around 10:18 to stop repeated requests.	Suggests the student's approval may have let the sign-in finish. The logs do not say who denied at 10:17.
10:20	Session created from 198.51.100.23. Student says they did not sign in after 09:05.	Suspicious and urgent, because a live session exists that the student says they did not start.

C2. Likely explanation, alternative and checks

Likely: someone other than the student had the password, triggered repeated MFA requests, and the student's approval completed the sign-in (an MFA fatigue pattern). **Alternative:** the student, or another of their devices, signed in from a different network, such as a phone hotspot or VPN, and the student does not remember or recognise it. An IP address identifies a network connection, not a person.

1. Check the identity provider's logs for the device, browser, MFA method and approximate location behind the 10:20 session, and whether it matches a device the student owns.
2. Ask the student which devices, networks, VPNs or apps they used around 10:00-10:20, and check whether the MFA prompt came to the student's registered phone.

C3. Three prioritised response actions (for the authorised IT team)

1. **Protect the account:** follow procedure to revoke active sessions and tokens, reset the password, and re-register MFA safely.
2. **Preserve evidence:** export authentication, MFA and session logs with timestamps before retention removes them, restrict access to them and record every action taken.
3. **Investigate:** review account changes and other sign-ins, look for similar activity on related accounts, and update the student through an official channel.

C4. Incident summary

On 18 October 2026, student07 signed in normally at 09:00 from the usual classroom IP. Between 10:14 and 10:16, two failed passwords and then a success came from 198.51.100.23, followed by an MFA denial, an approval at 10:18 and a session at 10:20. The student denies signing in after 09:05 but approved a prompt to stop repeated requests. This suggests possible unauthorised access, although the IP cannot identify a person. Priority is high because a session exists. IT should revoke sessions, reset the password, preserve logs and verify device details.

Task D: Review an AI security answer (25 marks)

D1. Five unsafe or unsupported claims and corrections

AI claim or action	Correction and evidence
"The email is safe because it uses HTTPS."	Wrong. HTTPS only encrypts the connection. The email also has mismatched sender and reply domains, urgency and a request for a password and OTP, so it should be verified through an official channel.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Unsupported. The logs show events from an IP address; they do not identify a person or show how the password was obtained. The data supports "suspicious", not "proven".
"MFA prevents every account compromise."	Wrong. In Task C the student's approval of an unexpected prompt may have let the sign-in succeed. MFA greatly helps but can be bypassed by prompt approval or phishing.
"Delete the suspicious logs."	Unsafe. The logs are the main evidence. They should be preserved securely for the authorised team.
"Send the student's password to support so they can test it."	Unsafe. Passwords and OTPs must never be shared with anyone. Support should use official reset and recovery procedures instead.

D2. Better prompt for an AI tool

"Analyse only the fictional email and synthetic sign-in log that I paste below. First list the facts directly shown in the evidence, then list your assumptions separately. Point out warning signs and say what cannot be concluded, for example you must not identify a person from an IP address. Do not ask for or repeat any password, OTP, identity document or real student data. Suggest safe, prioritised actions for the authorised IT team, state your level of uncertainty, and tell me what extra evidence would help."

D3. Corrected security advice

Do not trust a message just because it looks official or uses HTTPS; HTTPS only protects the connection. Verify scholarship claims through the college portal or a contact you found yourself, and never share a password, OTP or ID photo in reply to a message. If you already entered them, change the password from a trusted device, sign out unknown sessions and tell IT support. Deny sign-in prompts you did not start. The logs show repeated password attempts, an MFA approval and a new session from 198.51.100.23, which is suspicious but does not prove who used it or how the password was obtained. IT should protect the account, keep the logs as evidence and investigate before concluding.

D4. AI-use declaration and evidence notes

AI-use declaration: I used AI tools (ChatGPT and Claude) to help me understand the questions and to draft and proofread my answers. I reviewed and edited the content and checked it against the assessment evidence and the references below. I did not enter real passwords, OTPs, identity documents or personal data.

Evidence note 1: The fictional message and synthetic log in this assessment show warning signs and a suspicious sequence of events, but they cannot establish a real sender's identity or a person's identity.

Evidence note 2: CISA's Secure Our World guidance supports using strong unique passwords, MFA, updates and caution with phishing. NIST AI 600-1 discusses confabulation in generative AI, which is why AI output must be verified instead of trusted.

References

EWB Courses. *Assessment 01: Security Foundations.* Issued 18 October 2026, pp. 1-4.

Cybersecurity and Infrastructure Security Agency (CISA). *Secure Our World.* https://www.cisa.gov/secure-our-world

National Institute of Standards and Technology (NIST). *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, AI 600-1.*
https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf